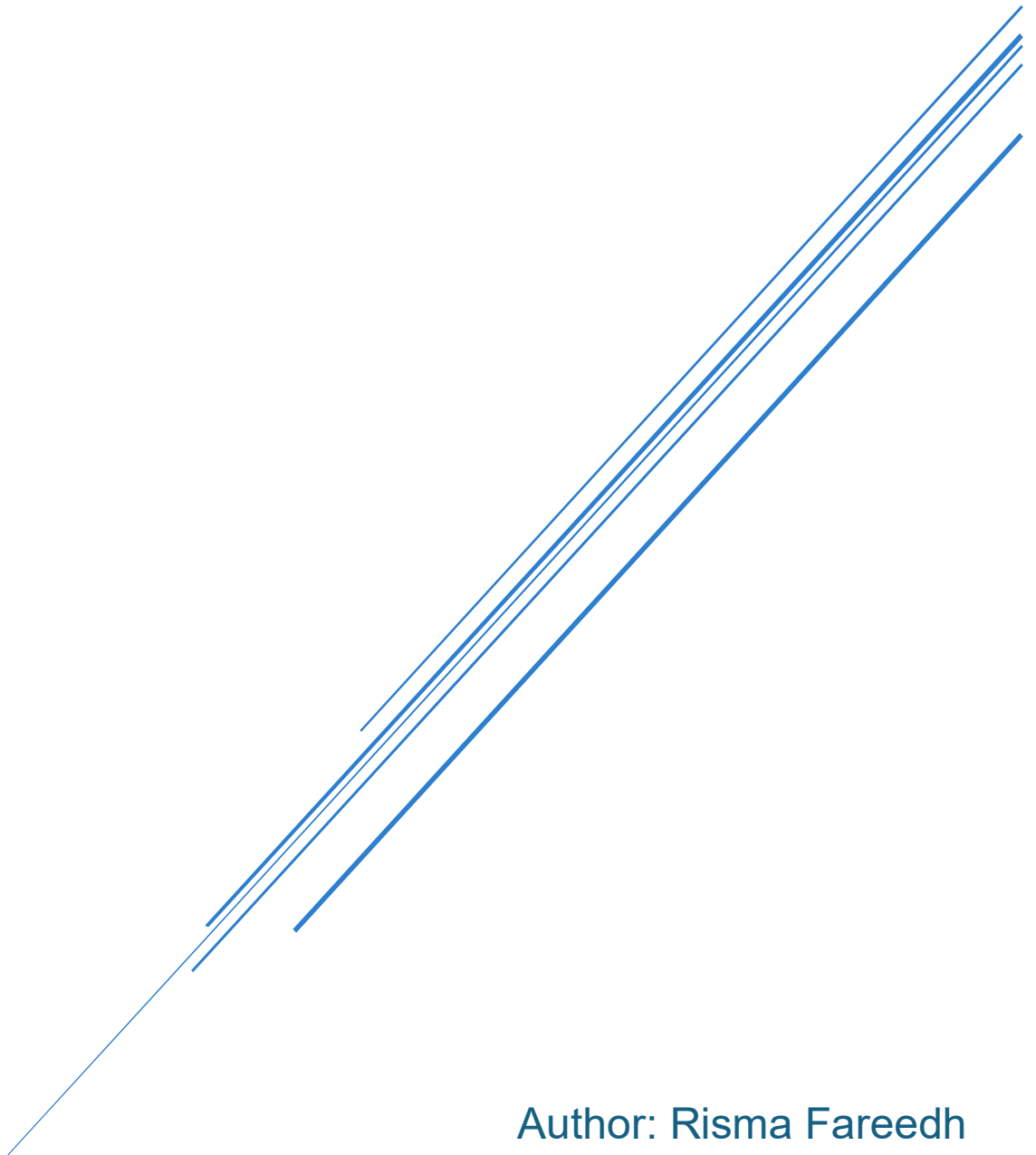


INFORMATION SECURITY POLICY

For Banking Industry



Author: Risma Fareedh
AION Campus
Governance, Risk & Compliance (GRC)

Industry Type: Banking

Bank Name: Q Bank (Fictional)

Policy Owner: Chief Information Security Officer (CISO)

Approval Date: 01 October 2025

Review Date: 01 October 2026

1. Purpose

The purpose of this Information Security Policy is to establish a framework for managing and protecting Q Bank's information assets. This policy ensures the confidentiality, integrity, and availability of information across all organizational units, processes, services, and IT assets while supporting compliance with ISO/IEC 27001:2022.

2. Scope

This policy applies to:

- All physical locations where Q Bank conducts operations, including corporate headquarters, regional and branch offices, ATM locations, and primary and secondary data centers.
- All organizational units including Retail Banking, Corporate & Investment Banking, Treasury & Finance, Risk & Compliance, IT, Customer Service, HR, and Administration.
- All banking-related processes and services such as account management, electronic and mobile banking, loan processing, credit/debit card management, treasury operations, customer support, and regulatory reporting.
- All IT systems, networks, applications, databases, and infrastructure supporting banking services, including core banking systems, internet/mobile banking platforms, payment processing systems, internal networks, communication systems, backup systems, and disaster recovery sites

Out of Scope:

- Non-banking activities like cafeteria services, building maintenance (outsourced), and unrelated third-party tenant operations.
- Activities or assets do not directly impacting confidentiality, integrity, or availability of banking information or services.

3. Policy Statement

Q Bank is committed to:

1. Protecting all information assets against unauthorized access, disclosure, alteration, and destruction.
2. Complying with legal, regulatory, and contractual information security requirements.
3. Ensuring all staff understand their roles and responsibilities related to information security.
4. Establishing and maintaining an Information Security Management System (ISMS) aligned with ISO/IEC 27001:2022.

5. Continually assessing, monitoring, and improving security controls to mitigate risks.

4. Roles and Responsibilities

- **Board of Directors:** Provide oversight, approve policies, and ensure top management commitment.
- **CISO:** Develop, implement, and maintain the ISMS; monitor compliance; report to management.
- **Department Heads:** Ensure that employees adhere to information security policies and procedures.
- **All Employees:** Follow security practices, report security incidents, and participate in security awareness programs.

5. Key Security Principles

1. **Confidentiality:** Protect sensitive information from unauthorized disclosure.
2. **Integrity:** Ensure information is accurate, complete, and safeguarded against unauthorized modification.
3. **Availability:** Ensure timely access to information and systems as required.
4. **Risk Management:** Identify, assess, and treat information security risks effectively.
5. **Compliance:** Align with ISO 27001 requirements, legal obligations, and regulatory frameworks.

6. Information Security Controls

Q Bank will implement controls across the following domains:

- Access management and authentication.
- Data classification, handling, and encryption.
- Network and endpoint security.
- Physical security and environmental controls.
- Business continuity and disaster recovery.
- Monitoring, logging, and incident response.
- Supplier and third-party risk management.
- Training and awareness programs for all staff.

7. Policy Enforcement

Violations of this policy may result in disciplinary actions, including termination of employment, contractual penalties, or legal action. The CISO will oversee investigations and corrective actions.

8. Review and Maintenance

This policy will be reviewed annually or when significant changes occur in the organizational structure, technology, regulatory requirements, or ISMS scope. Updates will be approved by the Board and communicated to all staff.